

北 京 邮 电 大 学

本科毕业设计（论文）中期进展情况检查表

学院	网络空间安全学院		专业	信息安全	
学生姓名	张艺翱	学号	2022211575	班级	2022211801
指导教师姓名	张淼	所在单位	北京邮电大学	职称	副教授
设计（论文）题目	（中文）基于强化学习的 Web 渗透测试大模型增强算法的研究与仿真				
	（英文）Research and Simulation of Large-Scale Web Penetration Testing Model Augmentation Algorithm Based on Reinforcement Learning				

主要内容： 毕业设计（论文）进展情况，字数一般不少于 1000 字。

一、研究背景

目前，围绕“基于强化学习的 Web 渗透测试大模型增强算法的研究与仿真”这一课题，我已按照任务书要求完成了文献调研、问题分析、总体方案设计、关键方法实现以及阶段性实验评估等工作，并在真实自动化渗透测试基准上完成了 AutoPenBench 的系统测试与结果整理。

首先，在前期调研与问题定义方面，我系统梳理了自动化渗透测试领域中“规则驱动工具—LLM 交互式 Agent—强化学习增强”三条主要技术路线，重点分析了传统脚本化工具、基于大模型的安全 Agent 以及强化学习方法在长时程、多轮交互安全任务中的优缺点。通过阅读相关公开研究和基准资料，我进一步明确了当前研究的核心困难：一是 Web 渗透测试本质上不是单轮问答，而是“观察—分析—执行—再观察”的多轮决策过程；二是环境反馈具有稀疏性和随机性，模型若只依赖终局成功信号，往往很难学到稳定有效的攻击策略；三是大模型在真实环境中容易出现动作格式错误、重复试错、推理链冗长以及面对失败无法自我纠偏等问题。基于这些认识，我明确了本课题的切入点，即把渗透测试任务建模为可交互的马尔可夫决策过程，在保留终局目标导向的同时，引入能够刻画中间真实进展的奖励设计，从而提升模型在长链条攻击任务中的稳定性与任务完成率。

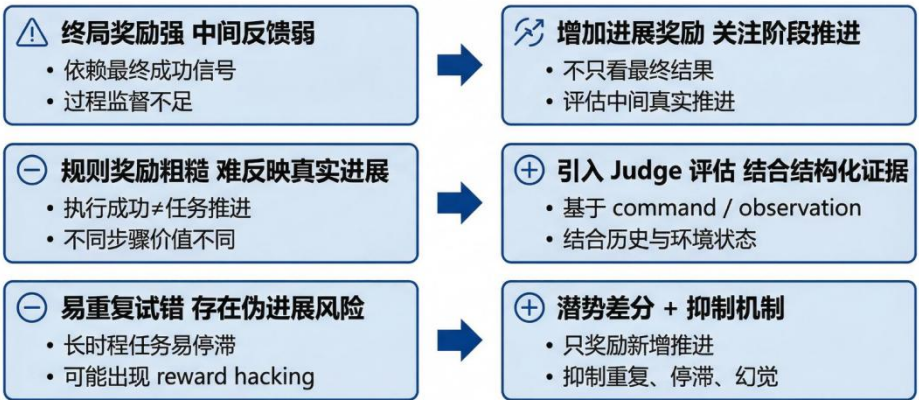


图 1 现有研究不足与本文切入点

二、技术路线

其次，在总体技术方案方面，我已经完成了“离线基础注入+在线交互强化”的两阶段训练框架设计，并将其落实为可执行的研究流程。参考公开论文中的两阶段强化学习思想，其核心做法是：先利用五百多个真实多步渗透测试 walkthrough 数据，让模型学习专家的基础攻击逻辑与操作习惯；随后再把模型放入可交互的 CTF/渗透测试环境中，通过多轮执行、接收环境反馈、反复试错和策略更新来进一步强化其实战能力。结合本课题的研究目标，我已将这一思想转化为自己的技术路线：先完成任务样本构造与提示词注入，再组织模型在在线环境中生成结构化动作，执行命令并接收环境回显，最后依据奖励信号通过 GRPO 算法进行策略更新。这样，模型不仅能够从离线数据中获得“会做什么”的知识，还能够在在线环

境中学会“做错了如何修正、做到哪一步算真正前进”。从课题推进角度看，这一框架已经完成了理论设计、模块划分和关键流程打通，为后续继续扩充数据集和开展更大规模训练奠定了基础。

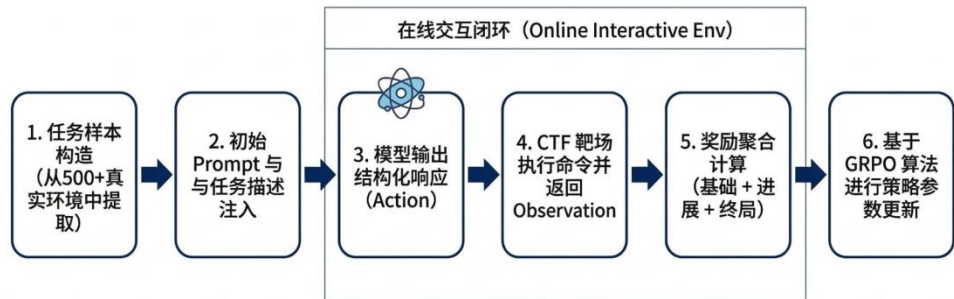


图 2 强化学习框架设计

再次，在环境建模与智能体交互机制方面，我已经完成了对渗透测试任务的 MDP 化抽象与多轮交互流程设计。具体而言，我将状态定义为“题目描述+历史命令轨迹+环境返回信息”的组合，将动作定义为模型生成并由解析器提取出的命令，将状态转移定义为命令执行后环境产生的新观测，将终止条件定义为成功获取目标 Flag 或达到最大交互轮数，并在此基础上定义对应奖励。与普通问答式训练不同，这种建模方式更适合描述渗透测试中的连续决策过程，因为每一步动作都会影响后续可见信息和攻击路径。为了保证模型输出可以被环境可靠执行，我进一步设计了严格的“观察—思考—行动”闭环解析结构：输入端包括 System Prompt、任务描述和历史 Observation，输出端被约束为反思、计划、思路和最终动作等结构化字段，并通过动作解析器提取真正用于执行的命令。这一部分工作已经完成方法论设计和格式规范，能够有效减少模型自由生成导致的格式漂移、命令混杂和无效回复问题，从工程实现上保证模型输出与真实执行环境之间的接口一致性。



图 3 交互式环境多轮任务 MDP 建模

在强化学习算法与奖励机制设计方面，目前我已经完成了基于 GRPO 的训练策略设计，以及基础环境奖励和进展奖励的组合方案设计。公开论文采用无 Critic 网络的 GRPO 进行多轨迹比较更新，其优点是能够直接比较同一任务下不同轨迹的相对优劣，降低复杂价值网络训练带来的不稳定性；论文在线阶段还设置了终局奖励、步骤奖励和失败惩罚，例如成功获取 Flag 给予+1.0 奖励，合法命令生成与成功执行分别给予小额正奖励，而命令格式错误、执行失败和错误提交 Flag 则给予负奖励。结合本课题在中期阶段的具体探索，我已经在基础 Flag 导向奖励之外，进一步引入了“进展奖励塑形”的思想：不是只在最后拿到 Flag

时奖励模型，而是结合环境真实变化，对发现新端口、识别新服务、获取凭证、实现权限提升等中间关键进展给予更细粒度反馈。同时，为避免模型通过重复刷同类动作“骗取奖励”，我还考虑了潜势差分、Judge 评估与 Anti-Hacking 约束等机制，使奖励更加关注“真实推进”而非“表面繁忙”。这一部分工作使得课题不再停留在简单复现层面，而是围绕长链条任务中的稀疏奖励难题，形成了具有自身特色的改进思路。

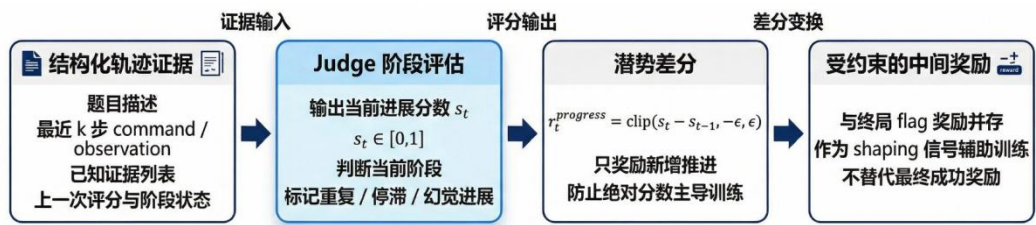


图 4 Judge 评估与 Anti Reward Hacking 机制

三、实验结果

在实验设计与阶段性实现方面，我已经完成了以 AutoPenBench 为核心基准的实验评估工作，并对结果进行了系统分析。AutoPenBench 是面向渗透测试 Agent 能力评估的重要基准，既关注最终任务是否成功完成，也关注中间子任务的完成情况。根据当前 PPT 中的实验结果，我的论文模型在 AutoPenBench 上的 Success Rate 达到了 24.2%，Subtask-Success 达到 33.4%。这一结果说明模型不仅在中间步骤上能够较稳定地推进任务，而且在端到端任务完成能力上已经达到较强水平。从横向对比看，在商业模型中，Gemini 2.5 Flash（带思维）为 27.3%，GPT-4o 为 21.2%，Claude 4 Opus/Claude 3 Opus 为 18.2%，OpenAI o1-preview 为 15.2%；在开源模型中，Qwen2.5-32B 为 12.1%，Qwen3-32B（带思维）为 9.1%，Qwen3-32B（不带思维）为 12.1%，Llama 3.1 405B Instruct 为 6.1%，Mixtral 8x22B Instruct 为 0.0%。可以看到，论文模型的 24.2% 已经超过 GPT-4o 等多种商业模型，也显著领先所有参与对比的开源模型，仅次于 Gemini 2.5 Flash 这一组结果。若从提升幅度来看，相比 Qwen2.5-32B 和 Qwen3-32B 等代表性开源大模型，成功率大致提升了约 12.1 至 15.1 个百分点；相比 GPT-4o 也高出 3.0 个百分点。这说明本课题所采用的强化学习增强路线，确实能够把基础模型的渗透测试能力从“会分析一部分子任务”推进到“更有可能完成完整攻击链”。

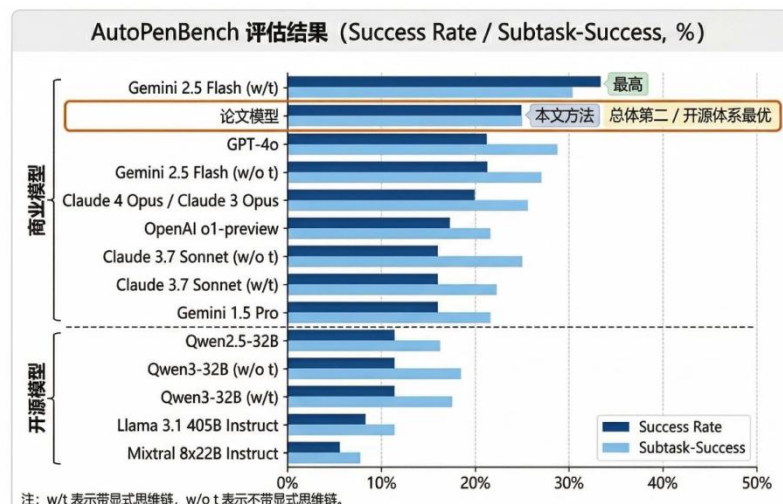


图 5 AutoPenBench 评估结果

除最终成功率外，我还对比分析了不同模型在中间子任务层面的表现。实验结果显示，Gemini 2.5 Flash（带思维）的 Subtask-Success 为 44.2%，论文模型为 33.4%，Qwen2.5-32B 为 37.9%，Qwen3-32B（不带思维）为 36.9%，GPT-4o 为 29.0%。这说明部分模型虽然能够在子任务层面取得较高覆盖率，但未必能把这些局部能力串联成稳定的端到端攻击链；而论文模型在保证较高子任务完成度的同时，最终整体成功率更高，说明其在“多步衔接、错误恢复、路径调整”方面更具优势。换言之，本课题现阶段取得的成绩，不只是“会做更多步骤”，更重要的是“能够把步骤连成结果”。这也是自动化渗透测试任务区别于一般单步安全问答的关键能力要求。

在消融实验方面，我也已经完成了对两阶段训练机制有效性的阶段性验证。根据现有结果，基座模型在 AutoPenBench 上的成功率仅为 3.0%；仅使用 Stage 1 的 SFT 后，成功率仍为 3.0%，说明单纯依赖监督微调难以显著提升端到端渗透测试能力；仅进行 Stage 1 的 GRPO 后，成功率提升到 9.1%；仅进行 Stage 2 的 GRPO 后，成功率同样为 9.1%；而将两个阶段联合起来后，成功率跃升至 24.2%，Subtask-Success 达到 33.4%。这一结果非常关键，它表明离线阶段提供了基础攻击知识和专家行为先验，在线阶段则让模型学会依据环境反馈进行自我修正和策略调整，二者缺一不可。也就是说，真正带来能力跃升的不是某个单独模块，而是“离线知识注入+在线交互强化”的协同作用。这一发现与本课题最初的研究判断是高度一致的，也说明当前技术路线具备充分的合理性和实验支撑。

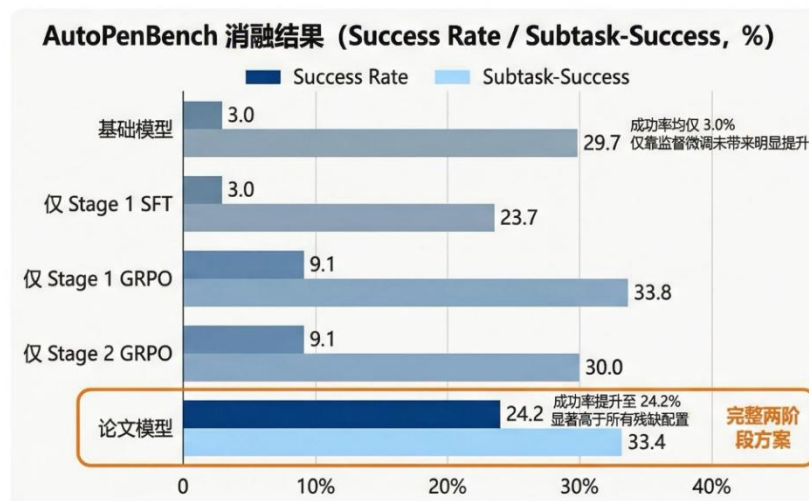
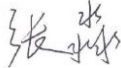
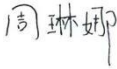


图 6 消融实验评估结果

综合来看，毕业设计目前已完成的任务可以概括为以下几个方面：第一，完成了课题背景梳理、问题定义和国内外相关研究分析，明确了自动化 Web 渗透测试中长时程、多轮交互与稀疏奖励的核心挑战；第二，完成了两阶段强化学习总体方案设计，形成了从任务样本、提示构造、结构化输出、环境执行到策略更新的完整流程；第三，完成了渗透测试任务的 MDP 建模、交互闭环设计和动作解析机制设计；第四，完成了基于 GRPO 的训练思路设计以及基础奖励、进展奖励和抗奖励作弊约束的研究与实现；第五，完成了 AutoPenBench 基准上的系统测试，并得到了具有竞争力的实验结果，验证了本课题方法在真实自动化渗透测试场景中的有效性；第六，完成了两阶段训练机制的消融分析，证明了课题方案的关键增益来源。总体而言，本课题中期阶段已经不再停留于方案设想，而是完成了从理论分析、方法构建到实验验证的关键过渡，具备了继续扩展自建数据集、补充更多基准测试并完善论文写作的坚实基础。

四、参考文献

- [1] Kong H, Hu D, Ge J, Li L, Li H, Li T. Pentest-R1: Towards Autonomous Penetration Testing Reasoning Optimized via Two-Stage Reinforcement Learning[EB/OL]. arXiv:2508.07382, 2025.
- [2] Weyssow M, Yang C, Chen J, Li Y, Huang H, Ang H W, et al. R2Vul: Learning to Reason about Software Vulnerabilities with Reinforcement Learning and Structured Reasoning Distillation[EB/OL]. arXiv:2504.04699, 2025.
- [3] Yu T, Liu L, Zhou Z, Xing F, Wang K, Yang Y. REFN: A Reinforcement-Learning-From-Network Framework against 1-day/n-day Exploitations[EB/OL]. arXiv:2508.10701, 2025.
- [4] Wang Z, Wang K, Wang Q, Zhang P, Li L, Yang Z, et al. RAGEN: Understanding Self-Evolution in LLM Agents via Multi-Turn Reinforcement Learning[EB/OL]. arXiv:2504.20073, 2025.
- [5] Simoni M, Fontana A, Rossolini G, Saracino A. Improving LLM Reasoning for Vulnerability

解 决 办 法	拟 采 取 的 办 法	1. 针对实验覆盖不足的问题，后续将增加训练后评测轮次，补充更多任务样本与不同难度设置，并引入 Cybench 等额外基准进行横向比较，形成更完整的实验结论。 2. 针对离线数据集与目标场景匹配度不足的问题，将围绕 Web/CTF 任务重新设计 stage1 数据集生成方案，重点提升任务描述、动作模板、推理过程和阶段性目标的针对性，从而增强模型冷启动阶段的有效性。		
指 导 教 师 签 字			日 期	2026 年 3 月 24 日
检 查 小 组 评 分 及 意 见		评分：29（总分：30） 毕业设计研究方案设计较为合理，已取得阶段性成果。建议：（1）深入挖掘研究特色，提炼具有创新性的核心要点；（2）细化时间节点，确保按期完成；（3）加强实验数据的系统化整理与分析。 组长签字： 2026 年 3 月 25 日		

注：此表仅供参考，各学院应围绕毕设目标达成度，结合人才培养目标、专业认证要求等进行个性化完善。